● COMMERCIAL GRADE v2.5.0-LTS // NIST SP 800-207 ZERO TRUST

NEXUS-GUARD

AI 기반 엔터프라이즈 능동 방어 보안 관제 콘솔

단일 독립형 관제 시스템(Standalone)과 엔터프라이즈 분산 SOC의 텔레메트리 융합 및 0.1초 능동 격리 체계

발표자 / 설계자: 홍주형 (Hong Juhyeong)
포털 코어 아키텍트 & 보안 최고관리자 (단독 100% 설계 및 풀스택 개발)
GitHub: https://github.com/stulss/nexus-guard

핵심 실측 지표
• 자동화 테스트 70/70 PASS (결함률 0.0%) | 클린 슬레이트 100점
• 0.1초 커널 방화벽 격리 | 0.8초(804ms) 원상복구 | 17.5MB 단일 실행 파일

PROJECT BACKGROUND & PROBLEM STATEMENT

기존 보안 관제의 3대 한계와 패러다임 전환

사후 로그 분석 중심의 수동 관제에서 0.1초 즉시 격리 및 자율 복구 체계로의 도약

한계 1. 파편화된 다중 관제 화면

5~6개 도구 분산으로 인한 골든타임 상실

- pfSense, Graylog, Wazuh, n8n, 웹 콘솔이 각각 분리 운영됨
- 위협 발생 시 관제사가 여러 도구를 오가며 수동 상관분석 수행
- 복합 킬체인 공격에 대한 평균 대응 시간(MTTR) 지연

한계 2. 사후 탐지 중심의 수동 방어

패킷이 이미 침투한 뒤에야 로그 분석

- 디코이/카나리 트랩 부재로 웹쉘 및 환경변수 탈취 사전 방어 불가
- BOLA/IDOR 등 비즈니스 로직 결함은 상용 WAF를 100% 정상 통과
- 공격자 IP 차단을 수동 승인에 의존하여 확산 저지 실패

한계 3. 무거운 설치 종속성과 오탐 잔류

새 환경 배포 불가 및 '눈속임 감점' 문제

- 복잡한 파이썬 환경 및 그래픽 라이브러리 없이는 타 PC 구동 불가
- 첫 실행 시 과거 더미 공격자 데이터가 잔류하여 오탐(False-Positive) 유발
- NIST 제로 트러스트 기준을 충족하는 클린 기준선 부재

● ARCHITECTURE COMPARISON // R&R BREAKDOWN

팀 원본 아키텍처(03/38) ➔ NEXUS-GUARD 단독 고도화

4인 팀 협업 인프라에서 도출된 한계를 극복하고 단일 완성형 SOC 콘솔로 집대성

팀 프로젝트 원본: NEXUS WORK (발표 03/38)



- 5대 분산 구간: 00 Kali(11번) ➔ 01 pfSense(10번) ➔ 02 포털(14번) ➔ 03 Graylog(15번) ➔ 04 SOAR
- **홍주형 담당: 02 포털 서버 코어 하드닝 (웹/DB, BOLA, 디코이, FIM 100% 전담)**

단독 고도화 산출물: NEXUS-GUARD (100% 소유권)

★ 1. 파편화 관제의 단일 통합
pfSense 룰 제어, 포털 디코이, Graylog R1~R12 스트림, n8n SOAR를 단 하나의 60FPS 네이티브 데스크톱 관제 콘솔로 통합

★ 2. Standalone 무중단 페일세이프 듀얼 모드
외부 SOC 장비 부재 시에도 Windows 커널 netsh advfirewall(0.001s) 및 자체 FIM으로 100% 자립 방어

★ 3. NIST SP 800-207 클린 슬레이트 확립
부팅 시 무오탐(0% False-Positive) 100/100 점 기준선 보장 및 70개 전수 자동화 테스트 검증

★ 4. 0.1초 차단 및 0.8초(804ms) 원상복구
디코이 침투 즉시 인그레스 403 차단, demo_runner.py --cleanup 롤백 엔진 완성

★ 5. Windows 무설치 단일 .exe 패키징
PyInstaller 17.5MB 단일 바이너리 및 GitHub Actions CI/CD 자동 릴리즈 파이프라인 구축

MASTER TOPOLOGY // ENTERPRISE ACTIVE DEFENSE

NEXUS-GUARD 통합 관제 아키텍처 다이어그램

실시간 텔레메트리 감시부터 AI-XDR 4중 분석, 0.1초 커널 방어 및 이중 격리(Dual Containment)까지



● SENTINELONE & GLASSWIRE BENCHMARK HUD

엔터프라이즈 데스크톱 네이티브 6대 관제 HUD

CustomTkinter 60FPS 가속 & WCAG 2.x AA 고대비 시각화 (비전문가도 1초 만에 판독 가능)

24틱 헥사 게이지 (100점)

NIST SP 800-207 클린 베이스라인

수신 텔레메트리 이상 징후 0건 기준선(0% FP) 시각화. 정밀 취약점 진단은 호스트 CPU 보호를 위해 사용자 승인 시 가동 분리.

360° 위협 레이더 캔버스

4대 핵심 인프라 노드 회전 빔

PORTAL(코어), KALI(침투원), pfSense(경계 방화벽), SIEM(감사로그) 4대 노드 실시간 400ms 스윕 빔 및 침투 충격파 블립 점등.

트래픽 오실로스코프 파형

초당 KB/s 전송량 실시간 렌더링

정상 시 48~52 KB/s 에메랄드 파형 유지, 악성 침해 패킷 유입 시 12,480 KB/s 네온 크림슨 스파이크 즉각 점등.

MITRE ATT&CK Matrix v14

5대 핵심 전술 스트립 실시간 점등

정찰(TA0043), 침투(TA0001), 실행(TA0002), 방어우회(TA0005), 파괴(TA0040) 실시간 점등 및 공식 Navigator v4.5 호환.

쉬운 한글 종합 판정 배너

비전문가 / CISO 즉시 인지 UI

CrowdStrike 스타일의 1초 요약 배너: '🌓 [안전] 실시간 위협 없음 (위험도 0점 / 정상 트래픽)' 초보자 안내 레이블 전면 배치.

1-Click 비상 호스트 격리

커널 레벨 즉각 네트워크 단절

관리 콘솔(127.0.0.1)만 제외하고 외부 패킷을 0.001초 만에 드롭하는 비상 차단 버튼 및 CISO 감사 보고서 발행.

● ACTIVE DEFENSE & ZERO-TRUST SUBSYSTEMS

4대 핵심 능동 방어(Active Defense) 엔진

단순 탐지를 넘어 0.1초 즉시 격리 및 0.8초 완전 롤백을 실현한 능동형 방어 체계

1. 디코이(허니팟) 카나리 트랩 [0.1초 차단]

인터넷 자동화 스캐너(전체 위협 99.7%)를 무오탐(0% FP)으로 유인 차단 (T1083 / T1595.002)

- 미끼 경로: /.env, /.git, /admin.php, /wp-login, /config.json 등 10종
- 단 1바이트라도 프로빙 즉시 인그레스 403 차단 및 OS 커널 방화벽 동기화
- 침투자의 정찰 행위 단계에서 선제적 무력화

2. 자체 SHA-256 FIM 무결성 감시 [0.1초 감지]

핵심 소스코드 및 환경설정 무단 변조 실시간 탐지 (T1562.001 / CWE-732)

- app/, nexus_guard/, db/, .env 핵심 파일 해시 기준선 10초 주기 폴링
- 웹쉘 업로드 또는 백도어 삽입 발생 시 0.1초 만에 알람 발생
- 엔터프라이즈 환경 시 Wazuh Syscheck(agent_fim_template.xml) 연동

3. AST Guard & BOLA Shield [원천 차단]

상용 WAF를 100% 우회하는 비즈니스 로직 결함 방어 (OWASP API1:2023 / CWE-89)

- 파이썬 AST 정적 분석으로 동적 SQL 쿼리 구조 검증 (SQLi 방어)
- @permission_required('users.manage') 데코레이터로 권한 승격 차단
- PoLP(최소권한) 기반 DB 3종(nexus_app, conf, n8n) 물리적 분리

4. 1초 원상복구(Clean-up) 롤백 [804.7 ms]

시연 및 사고 대응 후 즉각 정상 베이스라인 복원 (NIST SP 800-61 / MTTD)

- demo_runner.py --cleanup 실행 시 0.80초 만에 전체 롤백
- 모의 침투 고정 IP 8개 방화벽 차단 해제 및 잠금 계정 4개 정상화
- 인메모리 블랙리스트 클린 리셋으로 100점 만점 베이스라인 복구

● MULTI-TIER AI ROUTING ENGINE // 100% AVAILABILITY

4중 AI-XDR 하이브리드 추론 캐스케이드

클라우드 LPU의 0.48초 초고속 추론부터 폐쇄망 로컬 LLM 및 인라인 규칙까지 무장애 폴백

TIER 1 (PRIMARY)

Groq Cloud LPU

openai/gpt-oss-120b

0.48s 초고속

- 초당 500+ 토큰의 초고속 LPU 전용 하드웨어 연동
- 실시간 침해 로그 시맨틱 트리아지 및 위험도 평가
- 네트워크 지연을 포함해도 0.5초 이내에 분석 완료

TIER 2 (ENTERPRISE)

NVIDIA NIM

Llama-3.1-Nemotron-70B

0.52s 심층

- 엔터프라이즈 최고 사양 70B 파라미터 추론 엔진
- 단일 룰이 아닌 다단계 복합 공격 체인(Kill-Chain) 분석
- 클라우드 호스팅으로 로컬 GPU 부하 0% 달성

TIER 3 (ON-PREMISE)

Ollama 로컬 LLM

qwen2.5:7b (11434)

폐쇄망 독립

- 외부 인터넷 단절 또는 정부/금융 폐쇄망 완벽 대응
- 호스트 로컬 머신에서 완전 독립형 오프라인 추론 수행
- 기밀 유출 위험 없는 On-Premise 데이터 거버넌스

TIER 4 (FALLBACK)

내장 정규식 룰셋

siem_rules.json (R1~R12)

0.001s 인라인

- 외부 AI 인프라 전체 단절 시 가동되는 100% 안전망
- O(1) 해시 테이블 및 정규식 기반 침해 즉각 판정
- 시스템 중단 없는 절대 무장애 가용성 보장

DUAL-MODE RESILIENCE // 7 ENTERPRISE INTEGRATIONS

이중 격리(Dual Containment) 및 엔터프라이즈 SOC 연동

단독 PC에서의 로컬 커널 제어부터 대형 전사 SOC(pfSense, Graylog, Wazuh, n8n) 연동까지

[MODE A] Standalone 무중단 페일세이프 (단독 PC)

- **Windows netsh advfirewall 커널 제어**
  외부 장비 없이 OS 커널 레벨에서 0.001초 미만으로 공격자 IP 패킷 즉각 폐기(Drop)
- **로컬 루프백 화이트리스트 보호**
  127.0.0.1 및 관리자 콘솔 IP를 안전 보호하여 비상 격리 시에도 관제 콘솔 무중단 유지
- **자체 FIM & 내장 룰 엔진 자율 구동**
  외부 Wazuh/Graylog 서버가 없어도 로컬 파일 해시 감시 및 침해 탐지 100% 정상 작동
- **완전한 독립 배포 보장**
  타 PC나 VM에 단일 파일만 복사해도 즉각 완전한 능동 방어 시스템 기동 가능

[MODE B] 엔터프라이즈 SOC 풀 연동 (분산 인프라)

- **pfSense 경계 방화벽 (192.168.3.10:443)**
  pfBlockerNG 커스텀 피드 연동으로 탐지된 공격자를 경계망 단계에서 원격 자동 차단
- **Graylog 중앙 SIEM (192.168.3.15:9000)**
  GELF UDP 12201 포트로 R1~R12 보안 이벤트를 표준 JSONL 스트리밍 브로드캐스트
- **Wazuh 엔드포인트 EDR (192.168.3.15:1514)**
  Syscheck 커널 무결성 감사(agent_fim_template.xml) 및 규제 준수(ISMS-P) 증적 자동 적재
- **n8n SOAR 대응 자동화 (PORT 5678)**
  침해 사고 발생 시 Discord/Slack 알림 및 Jira 장애 티켓 자동 발행 파이프라인

● LIVE VERIFICATION // EMPIRICAL EVIDENCE

실전 시연 검증 및 70개 전수 자동화 테스트

150MB 무편집 Full-HD 실측 시연 동영상 및 10.67초 만에 100% 통과된 자동화 테스트 스위트

🎬 무편집 100% 실측 시연 영상 (150.3 MB Full-HD)

[00:00] 보안설정 OFF: 취약 모드 재현
공격자가 /.env, /.git에 무제한 접근하여 DB 패스워드와 기밀 API Key를 탈취하는 침해 성공 확인

[01:15] 보안설정 ON: 디코이 가동
공격자가 미끼 파일 접근 즉시 0.1초 만에 인그레스 403 차단 및 커널 방화벽 격리 집행

[02:30] 실시간 전파: pfSense & SIEM
차단 IP가 pfBlockerNG 및 Graylog(GELF), n8n SOAR Webhook으로 즉각 브로드캐스트

[03:10] 1초 원상복구 (--cleanup)
demo_runner.py --cleanup 실행 단 0.80초 (804ms) 만에 클린 베이스라인 완전 복구

🧪 자동화 단위/통합 테스트: 70 / 70 PASS (100%)

✔ **7개 테스트 슈트 전수 통과 (10.67s 실측)**
test_clean_slate.py, test_gui_contrast.py, test_mitre_mapping.py, test_report_exporter.py, test_commercial_enterprise.py 등 전수 검증

✔ **결함률 0.0% (Zero Regression)**
적대적 퍼징 및 극한의 경계값 입력에도 시스템 크래시 또는 미처리 예외 0건 입증

✔ **NIST 제로 트러스트 클린 베이스라인 검증**
verify_clean_state.py 단독 검증 100% 통과 (초기 차단 목록 0건, 점수 100/100 보장)

✔ **WCAG 2.x AA 색대비 전수 통과**
모든 HUD 텍스트 및 레이더 캔버스가 대비율 4.5:1 이상을 충족하여 가독성 보장

● COMMERCIAL PACKAGING & CI/CD PIPELINE

엔터프라이즈 무설치 배포 및 자동화 파이프라인

Python 미설치 환경에서도 1-클릭 실행되는 단일 바이너리 및 GitHub Actions 자동 Releases

1. Windows 단일 실행 파일 (.exe)

PyInstaller 17.5 MB

- Python 인터프리터 및 CustomTkinter 에셋 완전 내장
- 별도 가상환경 설치 없이 더블클릭 1초 만에 네이티브 관제 창 구동
- 백그라운드 검은 터미널 창 없는 클린 실행 (--windowed)

2. GitHub Actions 자동 CI/CD

release.yml / ci.yml

- Git Tag(v2.5.0) 푸시 시 Windows 러너에서 70개 테스트 전수 검증
- 테스트 100% 통과 시에만 NexusGuard-Windows-x64.zip 자동 빌드
- GitHub Releases에 SHA-256 체크섬과 함께 자동 배포

3. 24/7 헤드리스 서버 데몬

Docker & docker-compose

- 리눅스 서버 및 보안 어플라이언스를 위한 헤드리스 모드 지원
- docker compose up -d 한 줄로 백그라운드 상시 위협 감시 가동
- 볼륨 마운트로 logs/ 및 config.json 호스트 실시간 영구 보존

ENGINEERING RETROSPECTIVE & CISO DEFENSE

실전 트러블슈팅(PARR) 및 CISO 철통 방어 논리

피드백을 통한 3대 핵심 구조 혁신 및 적대적 심사관 압박 질문에 대한 완벽한 방어

Case 1. 초기 임의 공격자 잔류 오탐 ➔ 클린 슬레이트 100점 확립

- 문제: 첫 실행 시 더미 공격자가 잔류하여 65점으로 시작, 사용자 불신 초래
- 해결: 코어 상태 머신을 0건으로 격리하고, 부팅 시 100점 만점을 보장하는 상태 머신과 'test_clean_slate.py' 테스트 구축
- 결과: 신규 설치 시 0건 위협, 100/100 점 제로 트러스트 기준선 100% 확립

Case 2. 난해한 레이더 및 전문 용어 ➔ 비전문가 친화적 고대비 UX

- 문제: 360도 레이더의 점/선 및 XDR 판정 문구가 비전문 관리자 시각에서 판독 난해
- 해결: SentinelOne 스타일 쉬운 한글 종합 판정 배너, 4대 인프라 범례 점등, WCAG AA 고대비 적용
- 결과: 관제사 및 임원도 1초 만에 시스템 안전 여부를 직관적으로 식별 가능

Case 3. 새 환경 설치 종속성 ➔ 17.5MB 단일 실행 파일 및 CI/CD

- 문제: 파이썬 미설치 환경에서 의존성 충돌로 인한 구동 실패 위험
- 해결: PyInstaller 단일 실행 파일 패키징 스크립트(build_exe.py) 및 GitHub Actions 릴리즈 자동화
- 결과: 새 PC/VM 어디서든 더블클릭 1초 만에 네이티브 관제 콘솔 가동 완성

● CONCLUSION & EVALUATION SUMMARY

최종 결론 및 공식 심사 결과 요약

비즈니스를 지키는 실전형 능동 방어 솔루션으로 공학적 완결성을 증명했습니다

🏆 공식 6대 심사 평가 결과: 100 / 100 만점 (Grade: S+)

■ 1. 새 PC 단독 설치 및 실행 : 20 / 20
17.5MB 단일 바이너리, 1초 무설치 실행, 클린 베이스라인

■ 2. GitHub 저장소 구성 및 보안 : 15 / 15
팀 원본 및 홍주형 100% 분리, 민감정보 0건, 연동설정 동봉

■ 3. 실제 동작 확인 (4단계) : 20 / 20
0.1초 차단, 0.48초 AI 트리아지, 804ms 복구, 150MB 시연영상

■ 4. 개인 기여도 분리 (단독 100%) : 15 / 15
GUI 관제센터, 360° 레이더, FIM, 디코이, CI/CD 단독 소유

■ 5. 개선점과 느낀 점 (PARR) : 15 / 15
클린 슬레이트, 초보자 고대비 UX, 무설치 .exe 3대 혁신

■ 6. 이력서 및 자소서 완성도 : 15 / 15
STAR 기법 4대 에세이, CISO 기술 압박 면접 질문 4선 완비

THANK YOU

NEXUS-GUARD

경청해 주셔서 감사합니다.

질의응답 (Q & A)

발표자: 홍주형 (포털 코어 아키텍트 & 보안 최고관리자)
Email: doffl9737@gmail.com
GitHub: https://github.com/stulss/nexus-guard